

Guía de Explotación de Vulnerabilidades en la Aplicación ERP

Esta guía te mostrará cómo explotar las vulnerabilidades intencionales de XSS, CSRF y "SQL Injection" simulada en la aplicación.

1. Vulnerabilidad: Autenticación (Simulación de Inyección SQL)

Objetivo: Burlar el proceso de inicio de sesión.

Pasos:

1. **Accede a la página de Login:** Abre la aplicación en tu navegador (la página inicial).
2. **Intenta con credenciales válidas:**
 - **Usuario:** admin
 - **Contraseña:** admin1234
 - Haz clic en "Iniciar Sesión". Deberías acceder al Dashboard.
3. **Cierra sesión.**
4. **Intenta la "Inyección SQL":**
 - **Usuario:** admin (o cualquier usuario existente)
 - **Contraseña:** ' OR 1=1 -- (asegúrate de incluir los espacios y los guiones dobles al final)
 - Haz clic en "Iniciar Sesión".
 - **Resultado Esperado:** Deberías iniciar sesión correctamente, ya que la condición ' OR 1=1 -- hace que la lógica de autenticación siempre sea verdadera, simulando una inyección SQL exitosa.

2. Vulnerabilidad: Cross-Site Scripting (XSS)

Objetivo: Inyectar y ejecutar código JavaScript malicioso en la aplicación.

Pasos:

1. **Inicia sesión** en el Dashboard (puedes usar admin/admin1234 o la inyección SQL anterior).
2. **Ve a la sección "Agregar Nuevo Producto".**
3. **Inyecta un payload XSS en el campo "Nombre del Producto":**
 - **Nombre del Producto:** <script>alert('XSS Exitoso!');</script>
 - **Precio:** 100 (o cualquier número)
 - **Stock:** 10 (o cualquier número)
4. **Haz clic en "Agregar Producto".**
5. **Resultado Esperado:** Deberías ver una ventana emergente (alert) con el mensaje "XSS Exitoso!". Esto demuestra que el código JavaScript se ejecutó en el contexto de la aplicación.
6. **Observa la lista de productos:** El nombre del producto en la lista también mostrará la ejecución de tu script.
7. **Otros Payloads de XSS para probar:**
 -

- `<body onload="alert('XSS en Carga de Página');">` (Esto podría no funcionar directamente en la lista de productos, pero es un ejemplo de payload)

3. Vulnerabilidad: Cross-Site Request Forgery (CSRF)

Objetivo: Forzar al navegador de un usuario autenticado a enviar una solicitud no deseada.

Pasos:

1. **Inicia sesión** en el Dashboard de la aplicación ERP. Mantén esta pestaña abierta.
2. **Simula una página de atacante:** Abre una *nueva pestaña* en tu navegador.
3. **Pega el siguiente código HTML en un editor de texto** (o en una herramienta de desarrollo web) y guárdalo como `csrf_attack.html`. Luego, ábrelo en la nueva pestaña de tu navegador (simulando que el usuario visita una página maliciosa).
4. HTML

```
<!DOCTYPE html>

<html>

<head>

  <title>Página de Ataque CSRF</title>

</head>

<body>

  <h1>¡Has ganado un premio!</h1>

  <p>Haz clic aquí para reclamarlo...</p>

  <form action="http://localhost:8000/index.html" method="POST" id="csrfForm">

    <!-- La URL de acción debe ser la de tu aplicación ERP -->

    <input type="hidden" name="productName" value="Producto CSRF Inyectado">

    <input type="hidden" name="productPrice" value="99.99">

    <input type="hidden" name="productStock" value="1">

    <input type="submit" value="Reclamar Premio">

  </form>

  <script>

    // Opcional: Envío automático del formulario al cargar la página
```

```
// document.getElementById('csrfForm').submit();
```

```
</script>
```

```
</body>
```

```
</html>
```

5.

- **Nota:** Asegúrate de que la `action` del formulario (`http://localhost:8000/index.html` en el ejemplo) coincida con la URL donde tienes alojada tu aplicación ERP. Si estás usando una extensión de navegador para ejecutar el HTML, la URL puede ser diferente.
- 6. **Haz clic en el botón "Reclamar Premio"** en la página del atacante (o si descomentas el JavaScript, se enviará automáticamente).
- 7. **Vuelve a la pestaña de tu aplicación ERP.**
- 8. **Resultado Esperado:** Deberías ver un nuevo producto llamado "Producto CSRF Inyectado" en la lista de productos del Dashboard, incluso si no lo agregaste directamente desde la interfaz de la aplicación. Esto demuestra que la solicitud fue forzada desde otra página.

4. Vulnerabilidad: Inyección SQL (Simulada en la Búsqueda de Productos)

Objetivo: Manipular la lógica de búsqueda para obtener resultados no deseados o inyectar datos.

Pasos:

1. **Inicia sesión** en el Dashboard.
2. **Ve a la sección "Buscar Productos".**
3. **Prueba la inyección de "siempre verdadero":**
 - **Término de Búsqueda:** `' OR 1=1 --`
 - Haz clic en "Buscar".
 - **Resultado Esperado:** La aplicación debería mostrar *todos* los productos existentes, ignorando el término de búsqueda original, simulando una inyección `OR 1=1`.
4. **Prueba la inyección de "UNION SELECT":**
 - **Término de Búsqueda:** `' UNION SELECT 5, 'Producto Inyectado SQL', 777.77, 7 --`
 - Haz clic en "Buscar".
 - **Resultado Esperado:** La lista de resultados de búsqueda debería incluir un producto con los detalles que inyectaste (`Producto Inyectado SQL`, Precio: \$777.77, Stock: 7), simulando cómo un atacante podría añadir datos arbitrarios a los resultados de una consulta.